

Phishing Analysis Simulation Report

Name : Syed Azhar Uddin Ali Khan

Role : Cybersecurity Analyst Intern

Date : 05/09/2026

Objective

The purpose of this task is to train cybersecurity analysts in identifying phishing emails, understanding attacker techniques, and learning preventive measures against email-based cyberattacks.

This exercise focuses on:

- Detecting phishing indicators
 - Understanding social engineering tactics
 - Identifying spoofed email behavior
 - Analyzing malicious links
 - Learning preventive and defensive strategies
-

1. Introduction to Phishing Attacks

What is Phishing?

Phishing is a cyberattack technique where attackers impersonate trusted organizations or individuals to trick victims into:

- Revealing passwords
- Sharing banking details
- Downloading malware
- Clicking malicious links
- Transferring money
- Providing sensitive corporate information

Phishing is one of the most common initial attack vectors used in:

- Data breaches
 - Ransomware attacks
 - Credential theft
 - Business Email Compromise (BEC)
 - Financial fraud
-

2. Common Types of Phishing

Type	Description
Email Phishing	Mass emails pretending to be trusted companies
Spear Phishing	Targeted phishing aimed at specific individuals
Whaling	Attacks targeting executives or senior officials
Clone Phishing	Copying legitimate emails with malicious modifications
Smishing	Phishing through SMS
Vishing	Voice-call phishing
Business Email Compromise	Fake executive/vendor email scams

3. Sample Phishing Email

Simulated Phishing Email

From: support-paypal@security-update-alert.com

To: employee@company.com

Subject: Urgent: Your PayPal Account Has Been Suspended

Dear Customer,

We detected unusual activity in your PayPal account. Your account has been temporarily suspended for security reasons.

To restore access immediately, please verify your account by clicking the link below:

<http://paypal-account-verification-secure.com/login>

Failure to verify within 24 hours will result in permanent account suspension.

Thank you,

PayPal Security Team

4. Visual Representation of the Phishing Email

Email Layout Visualization

| From: support-paypal@security-update-alert.com |
Subject: Urgent: Your PayPal Account Has Been Suspended

Dear Customer,

We detected unusual activity in your PayPal account.

Click below to verify immediately:

<http://paypal-account-verification-secure.com/login>

Failure to act within 24 hours will permanently suspend
your account.

- PayPal Security Team

5. Phishing Email Analysis

A. Sender Spoofing Analysis

Suspicious Sender Address

support-paypal@security-update-alert.com

Why It Is Suspicious

A legitimate PayPal email should come from:

@paypal.com

Instead, the attacker uses:

@security-update-alert.com

This is a spoofed or deceptive domain designed to appear legitimate.

Visual Breakdown

Legitimate Domain:

support@paypal.com

Phishing Domain:

support-paypal@security-update-alert.com

^

Fake domain used

B. Suspicious Link Analysis

Malicious URL

http://paypal-account-verification-secure.com/login

Indicators of Malicious Links

Indicator	Explanation
Uses HTTP instead of HTTPS	No encryption
Fake domain name	Not owned by PayPal
Long misleading text	Designed to appear trustworthy
Keyword stuffing	Uses "paypal", "secure", "verification"

URL Visualization

http://paypal-account-verification-secure.com/login

|-----|

Fake domain

C. Social Engineering Techniques Used

Phishing attacks rely heavily on manipulating human psychology.

1. Urgency

Message Used

Failure to verify within 24 hours...

Purpose

To pressure victims into acting quickly without thinking critically.

2. Fear

Message Used

Your account has been suspended

Purpose

Creates panic and emotional reaction.

3. Authority Impersonation

Message Used

PayPal Security Team

Purpose

Pretends to represent a trusted organization.

4. Generic Greeting

Message Used

Dear Customer

Purpose

Mass phishing campaigns often avoid using real names.

6. Indicators of Phishing

Indicator	Present in Email
Suspicious sender	Yes
Fake domain	Yes
Urgent language	Yes

Indicator	Present in Email
-----------	------------------

Threatening consequences	Yes
--------------------------	-----

Generic greeting	Yes
------------------	-----

Suspicious link	Yes
-----------------	-----

Request for verification	Yes
--------------------------	-----

7. Why This Email Is Malicious

Primary Reasons

1. Credential Theft Attempt

The attacker aims to steal:

- Username
 - Password
 - Banking information
 - Credit card details
-

2. Fake Website Redirection

The link likely redirects users to a counterfeit PayPal login page.

3. Potential Malware Delivery

Some phishing websites install:

- Keyloggers
 - Trojans
 - Ransomware
 - Browser hijackers
-

4. Identity Theft Risk

Stolen information may be used for:

- Financial fraud
- Account takeover
- Unauthorized transactions

8. Attack Flow Diagram

Attacker Sends Fake Email

|

v

Victim Clicks Malicious Link

|

v

Fake Login Page Opens

|

v

Victim Enters Credentials

|

v

Attacker Steals Information

|

v

Financial Fraud / Account Takeover

9. Technical Email Header Indicators

Common Header Red Flags

Header Field Suspicious Behavior

Reply-To Different from sender

SPF Failure Domain verification fails

DKIM Failure Email signature invalid

Received Path Originates from unknown server

10. How Organizations Prevent Phishing

A. Technical Controls

1. Email Security Gateways

These systems filter:

- Malicious attachments
- Suspicious links
- Spam emails

Examples:

- Microsoft Defender for Office 365
- Proofpoint
- Mimecast

2. SPF, DKIM, and DMARC

SPF (Sender Policy Framework)

Verifies authorized sending servers.

DKIM (DomainKeys Identified Mail)

Validates email integrity.

DMARC

Defines email authentication policies.

3. Multi-Factor Authentication (MFA)

Even if passwords are stolen, MFA adds an additional security layer.

4. URL Filtering

Blocks known malicious websites.

B. Human-Layer Protection

Security Awareness Training

Employees should learn to identify:

- Suspicious links
- Fake domains
- Urgent requests
- Social engineering tactics

Verification Practices

Users should verify requests through:

- Official websites
 - Known phone numbers
 - Internal communication channels
-

11. Best Practices for Users

Best Practice	Purpose
Verify sender address	Detect spoofing
Hover over links before clicking	Inspect destination URL
Avoid downloading unknown attachments	Prevent malware infection
Enable MFA	Additional account protection
Report suspicious emails	Help security teams investigate
Avoid urgent emotional reactions	Reduce manipulation success

12. SOC Analyst Perspective

What a Security Analyst Should Do

Step 1 — Identify Threat Indicators

- Suspicious domains
 - Malicious links
 - Spoofed sender
-

Step 2 — Contain Threat

- Block sender domain
 - Quarantine email
 - Alert users
-

Step 3 — Investigate Impact

Determine:

- Who clicked the link
 - Whether credentials were entered
 - Whether malware executed
-

Step 4 — Remediation

- Reset passwords
 - Revoke sessions
 - Scan endpoints
 - Update detection rules
-

13. Indicators of Compromise (IoCs)

IoC Type	Example
Malicious Domain	paypal-account-verification-secure.com
Suspicious Sender	security-update-alert.com
Fake URL Pattern	account-verification-secure
Credential Harvesting Page	Fake PayPal login portal

14. Real-World Impact of Phishing

Phishing attacks can result in:

- Financial loss
 - Data breaches
 - Ransomware infections
 - Corporate espionage
 - Reputation damage
 - Regulatory penalties
-

15. Conclusion

Phishing remains one of the most dangerous and effective cyberattack methods because it exploits human behavior rather than technical vulnerabilities alone.

This simulation demonstrated how attackers use:

- Sender spoofing
- Fake domains
- Urgency
- Fear tactics
- Social engineering

to manipulate victims into revealing sensitive information.

Effective defense requires a combination of:

- Technical controls
- Employee awareness
- Email authentication
- Continuous monitoring
- Incident response readiness

Understanding phishing indicators is a critical skill for cybersecurity analysts and SOC teams.

16. Final Outcome

Skills Learned

- Email threat analysis
- Phishing detection
- Social engineering awareness
- URL inspection
- Security awareness practices
- Incident response fundamentals

17. Additional Visual: Phishing Detection Checklist

PHISHING DETECTION CHECKLIST

[] Is the sender domain legitimate?

- ☐ Does the email create urgency?
- ☐ Are there suspicious links?
- ☐ Is the greeting generic?
- ☐ Are there grammar/spelling mistakes?
- ☐ Is sensitive information requested?
- ☐ Does the link match the real website?
- ☐ Is HTTPS missing?

If multiple answers are YES:

Potential phishing attack detected.
